

RELATÓRIO DE AVALIAÇÃO DE VULNERABILIDADE

Instituição:

Faculdade de Tecnologia SENAI Gaspar Ricardo Júnior

Integrantes do Grupo:

Julia de Lima Torres

Luis Henrique Sampaio

Valentina de Oliveira Leite

1. Introdução e Justificativa

Este relatório apresenta a Avaliação de Vulnerabilidades e o Pentest realizados na aplicação Monitoramento Inteligente de Plantas. O sistema foi desenvolvido utilizando Spring Boot, PostgreSQL, Docker e frontend web. A segurança da informação é um fator essencial para garantir confidencialidade, integridade e disponibilidade dos dados, justificando a realização dos testes descritos neste documento.

2. Objetivos e Escopo da Avaliação

O objetivo da avaliação foi identificar vulnerabilidades técnicas e falhas de configuração que possam comprometer a segurança do sistema. O escopo incluiu o backend, endpoints da API, configuração do Swagger, comunicação HTTP e banco de dados. Testes de infraestrutura externa e engenharia social ficaram fora do escopo.

3. Metodologia

Foi adotada uma metodologia de testes do tipo caixa cinza, combinando varredura automatizada, análise manual e simulação controlada de ataques.

3.1 Configuração do Ambiente e Ferramentas de Testes Automatizados

Os testes foram realizados em ambiente local, utilizando Docker Desktop no sistema operacional Windows 10. As ferramentas utilizadas incluíram Swagger (OpenAPI), navegador web e análise manual de configuração. A varredura automatizada foi conduzida por meio de inspeção de endpoints expostos e análise de respostas HTTP.

3.2 Pentest: Exploração das Vulnerabilidades Seleccionadas

Foram seleccionadas duas vulnerabilidades para exploração: ausência de autenticação em endpoints sensíveis e configuração permissiva de CORS. Ambas foram escolhidas devido ao impacto potencial sobre a confidencialidade e integridade do sistema.

4. Resultados

4.1 Resultados da Varredura Automatizada

As vulnerabilidades encontradas foram classificadas em níveis de risco baixo, médio e alto. Entre elas destacam-se: CORS permissivo (risco médio), Swagger exposto em ambiente produtivo (risco médio) e ausência de autenticação em rotas específicas (risco alto).

4.2 Resultados do Pentest

Durante o pentest, foi possível acessar endpoints sem autenticação e realizar requisições a partir de origens externas não confiáveis, simulando ataques de acesso não autorizado. O impacto potencial inclui exposição de dados e comprometimento da API.

5. Discussão

Os resultados demonstram falhas comuns em aplicações em fase inicial de desenvolvimento. As vulnerabilidades identificadas podem ser mitigadas com a implementação de autenticação JWT, restrição adequada de CORS e segregação de ambientes de desenvolvimento e produção.

6. Conclusão

Conclui-se que a aplicação Valentina apresenta um nível de segurança aceitável para fins acadêmicos, porém necessita de melhorias antes de um uso em produção. O teste proporcionou aprendizado prático sobre segurança da informação e pentest em aplicações web.

7. Referências

OWASP Foundation. OWASP Top 10 Web Application Security Risks. Spring Security Documentation. Docker Security Best Practices.